

Reporte Ejecutivo de Gestión de Riesgos

Clínica Privada — Registro Inicial de Riesgos de Seguridad de la Información

Preparado para: Directorio de la clínica | Preparado por: Arturo Marín, Responsable de Seguridad de la Información | Fecha: Septiembre 2026

1. Resumen Ejecutivo

Tras la auditoría externa reciente, que identificó debilidades en la gestión de riesgos de la institución, se implementó un proceso formal de identificación, evaluación y tratamiento de riesgos utilizando la herramienta SimpleRisk. Se relevaron **7 riesgos específicos** del contexto operativo de la clínica (historias clínicas digitales, facturación, datos de obra social e infraestructura), abarcando aspectos de confidencialidad, integridad, disponibilidad, cumplimiento legal y continuidad operativa. Del análisis se desprende un riesgo de nivel **crítico** (ataque de ransomware/phishing) y cinco riesgos de nivel **alto** que requieren tratamiento prioritario en el corto plazo. Se definieron 3 planes de acción concretos para los riesgos de mayor severidad, con responsables, plazos y presupuesto asignado.

2. Top 5 Riesgos por Nivel

ID	Riesgo	Prob.	Impacto	Nivel
R01	Ransomware / phishing dirigido a personal administrativo	4	5	Crítico
R02	Acceso no autorizado a historias clínicas	3	4	Alto
R03	Corte prolongado de energía eléctrica	3	4	Alto
R04	Pérdida o robo de notebook sin cifrado	3	4	Alto
R06	Incumplimiento normativo (falta de política de privacidad)	4	3	Alto

Nota: clasificación según matriz de riesgo de la cátedra (Probabilidad × Impacto, escala 1-25). El motor interno de SimpleRisk normaliza estos valores a una escala 0-10, por lo que puede mostrar niveles internos más bajos para los mismos datos (ver detalle metodológico en el informe técnico).

3. Estado de los Planes de Acción

Riesgo	Estrategia	Responsable	Presupuesto	Vencimiento	Estado
R01 — Ransomware	Mitigar	Resp. de TI	USD 3.000	05/11/2026	Planificado
R02 — Acceso no autorizado	Mitigar	Resp. de TI	USD 800	21/10/2026	Planificado
R05 — Backup sin probar	Mitigar	Resp. de TI / DBA	USD 500	06/10/2026	Planificado

4. Recomendaciones Prioritarias

- Aprobar la inversión en una solución EDR y esquema de backups offline (3-2-1) dentro de los próximos 60 días para mitigar el riesgo crítico de ransomware, que podría paralizar la atención de los ~800 pacientes diarios.
- Implementar control de acceso basado en roles (RBAC) sobre las historias clínicas electrónicas, eliminando el uso de credenciales compartidas entre el personal.
- Evaluar la adquisición de un generador de respaldo para garantizar la continuidad operativa ante cortes de energía prolongados.
- Formalizar una política de privacidad y designar un responsable de protección de datos personales, dando respuesta directa a la observación de la auditoría externa y a los requisitos de la Ley 25.326.
- Establecer un cronograma de pruebas periódicas de restauración de backups de la base de datos clínica, actualmente no verificados.